

NORMA
BRASILEIRA

ABNT NBR
ISO/IEC
38500

Terceira edição
13.03.2025

Tecnologia da informação — Governança de TI para a organização

Information technology — Governance of IT for the organization



ICS 35.020



ASSOCIAÇÃO
BRASILEIRA
DE NORMAS
TÉCNICAS

Número de referência
ABNT NBR ISO/IEC 38500:2025
25 páginas

© ISO/IEC 2024 - © ABNT 2025



© ISO/IEC 2024

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT, único representante da ISO no território brasileiro.

© ABNT 2025

Todos os direitos reservados. A menos que especificado de outro modo, nenhuma parte desta publicação pode ser reproduzida ou utilizada por qualquer meio, eletrônico ou mecânico, incluindo fotocópia e microfilme, sem permissão por escrito da ABNT.

ABNT

Av. Treze de Maio, 13 - 28º andar

20031-901 - Rio de Janeiro - RJ

Tel.: + 55 21 3974-2300

Fax: + 55 21 3974-2346

abnt@abnt.org.br

www.abnt.org.br

Sumário	Página
Prefácio Nacional	vi
Introdução	viii
1 Escopo	1
2 Referências normativas	1
3 Termo e definição	1
4 Boa governança de TI	3
4.1 Resultados da boa governança de TI	3
4.1.1 Visão geral	3
4.1.2 Desempenho eficaz	4
4.1.3 Administração responsável	4
4.1.4 Comportamento ético	5
4.2 Princípios, modelo e estrutura	5
5 Princípios para a governança de TI	6
5.1 Visão geral	6
5.2 Propósito	8
5.2.1 Princípio	8
5.2.2 Implicações de governança para o uso de TI	8
5.2.3 Resultados	8
5.3 Geração de valor	8
5.3.1 Princípio	8
5.3.2 Implicações de governança para o uso de TI	8
5.3.3 Resultados	9
5.4 Estratégia	9
5.4.1 Princípio	9
5.4.2 Implicações de governança para o uso de TI	9
5.4.3 Resultados	10
5.5 Supervisão	10
5.5.1 Princípio	10
5.5.2 Implicações de governança para o uso de TI	10
5.5.3 Resultados	11
5.6 Responsabilização	11
5.6.1 Princípio	11
5.6.2 Implicações de governança para o uso de TI	11
5.6.3 Resultados	12
5.7 Engajamento de partes interessadas	12
5.7.1 Princípio	12
5.7.2 Implicações de governança para o uso de TI	12
5.7.3 Resultados	13
5.8 Liderança	13
5.8.1 Princípio	13
5.8.2 Implicações de governança para o uso de TI	13

Exemplar para uso exclusivo - INSTITUTO RUI BARBOSA - IRB - 58.723.800/0001-10

5.8.3 Resultados13

5.9 Dados e decisões14

5.9.1 Princípio14

5.9.2 Implicações de governança para o uso de TI.....14

5.9.3 Resultados14

5.10 Governança de riscos15

5.10.1 Princípio15

5.10.2 Implicações de governança para o uso de TI.....15

5.10.3 Resultados15

5.11 Responsabilidade social15

5.11.1 Princípio15

5.11.2 Implicações de governança para o uso de TI.....16

5.11.3 Resultados16

5.12 Viabilidade e desempenho ao longo do tempo16

5.12.1 Princípio16

5.12.2 Implicações de governança para o uso de TI.....16

5.12.3 Resultados17

6 Modelo para a governança de TI.....17

6.1 Introdução17

6.2 Governança da prática de TI18

6.2.1 Envolver as partes interessadas18

6.2.2 Avaliar.....19

6.2.3 Dirigir.....19

6.2.4 Monitorar19

6.3 Gestão da prática de TI.....19

6.4 *Framework* para a governança de TI19

7 *Framework* para a governança de TI20

7.1 Geral20

7.2 Elementos do *framework*.....21

7.2.1 Geral21

7.2.2 Direção21

7.2.3 Capacidade21

7.2.4 Política.....22

7.2.5 Delegação23

7.2.6 Desempenho23

7.2.7 Responsabilização24

Bibliografia.....25

Figuras

Figura 1 – Modelo para governança de TI.....18

Figura 2 – *Framework* para a governança de TI.....20

Tabelas

Tabela 1 – Governança de TI – Visão geral das ferramentas5

Tabela 2 – Visão geral dos princípios de governança organizacional7



Exemplar para uso exclusivo - INSTITUTO RUI BARBOSA - IRB - 58.723.800/0001-10

Prefácio Nacional

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas pelas partes interessadas no tema objeto da normalização.

Os Documentos Técnicos internacionais adotados são elaborados conforme as regras da ABNT Diretiva 3.

A ABNT chama a atenção para que, apesar de ter sido solicitada manifestação sobre eventuais direitos de patentes durante a Consulta Nacional, estes podem ocorrer e devem ser comunicados à ABNT a qualquer momento (Lei nº 9.279, de 14 de maio de 1996).

Os Documentos Técnicos ABNT, assim como as Normas Internacionais (ISO e IEC), são voluntários e não incluem requisitos contratuais, legais ou estatutários. Os Documentos Técnicos ABNT não substituem Leis, Decretos ou Regulamentos, aos quais os usuários devem atender, tendo precedência sobre qualquer Documento Técnico ABNT.

Ressalta-se que os Documentos Técnicos ABNT podem ser objeto de citação em Regulamentos Técnicos. Nestes casos, os órgãos responsáveis pelos Regulamentos Técnicos podem determinar as datas para exigência dos requisitos de quaisquer Documentos Técnicos ABNT.

A ABNT NBR ISO/IEC 38500 foi elaborada no Comitê Brasileiro de Tecnologias da Informação e Transformação Digital (ABNT/CB-021), pela Comissão de Estudo de Gestão e Governança de TI (CE 021:040.004). O Projeto de Revisão foi submetido à Consulta Nacional no período de 05.02.2025 a 06.03.2025.

A ABNT NBR ISO/IEC 38500 é uma adoção idêntica, em conteúdo técnico, estrutura e redação, à ISO/IEC 38500:2024, que foi elaborada pelo *Joint Technical Committee Information Technology* (ISO/IEC JTC 1), *Subcommittee IT service management and IT governance* (SC 40).

A ABNT NBR ISO/IEC 38500:2025 cancela e substitui a ABNT NBR ISO/IEC 38500:2018, a qual foi tecnicamente revisada.

O Escopo em inglês da ABNT NBR ISO/IEC 38500 é o seguinte:

Scope

This document provides guiding principles for members of governing bodies of organizations and those that support them on the effective, efficient and acceptable use of information technology (IT) within their organizations.

This document is applicable to:

- *the governance of the organization's current, and future, use of IT;*
- *the governance of IT as a domain of governance of organizations.*

In terms of audience, this document is applicable to:

- *all organizations, including public and private companies, government entities, and not-for-profit organizations;*
- *organizations of all sizes, from the smallest to the largest, regardless of the extent of their use of IT.*



Introdução

O uso da tecnologia da informação (TI) é indispensável para o sucesso da maioria das organizações, não apenas como uma função de suporte, mas sobretudo, por sua capacidade de transformação organizacional. A TI permite novos modelos de negócios e pode melhorar substancialmente os resultados da organização para atender às necessidades e às expectativas das partes interessadas. A crescente ameaça da segurança cibernética e dos riscos decorrentes das tecnologias emergentes aumentam esse foco.

O potencial crescente da TI atual e futura requer a aplicação adequada da governança de TI para assegurar que ela cumpra o propósito da organização de forma eficaz, responsável e ética, e que esteja alinhada com o(s) direcionamento(s) estratégico(s) da organização.

O objetivo deste documento é fornecer orientação aos órgãos de governança sobre o uso responsável, inovador, sustentável e estratégico de TI, dados e recursos digitais, para que suas organizações possam cumprir seu propósito e atender satisfatoriamente à expectativa das partes interessadas. Este documento fornece orientações baseadas em princípios e, por conseguinte, não inclui pormenores específicos acerca de sua implementação.

Ele utiliza três ferramentas para o órgão de governança, associando práticas de governança e gestão a fim de alcançar a boa governança de TI:

- 1) Princípios para a governança de TI — aplicar esses princípios ao uso responsável e estratégico de TI pode tornar uma organização mais ágil e adaptativa.
- 2) Modelo para a governança de TI — o modelo apresenta as principais tarefas e interações de governança em toda a organização, leva a uma clareza na tomada de decisões e das responsabilidades para todos os aspectos do uso de TI.
- 3) Framework para a governança de TI — a estrutura descreve como os elementos e os arranjos de governança de TI operam na organização, o que ajuda a assegurar que as ações críticas de governança sejam consideradas e aplicadas ao uso de TI no contexto organizacional.

Como a governança de TI é um domínio da governança das organizações, este documento se alinha à ABNT NBR ISO 37000 e aos seus princípios de governança. Este documento também pode ser usado em conjunto com outros códigos e princípios de governança para uma governança eficaz. Este documento pode ser usado de forma independente ou para atualizar a governança atual com base na edição anterior da ABNT NBR ISO/IEC 38500.

Este documento é dirigido principalmente ao órgão de governança, mas reconhece que a governança ocorre em toda a organização. Portanto, fornece orientação sobre a prática de governança de TI em toda a organização, incluindo a interação e a colaboração de todas as pessoas, independentemente de sua descrição funcional.

Tecnologia da informação — Governança de TI para a organização

1 Escopo

Este documento fornece os princípios orientadores para os membros dos órgãos de governança das organizações e aqueles que os apoiam no uso eficaz, eficiente e aceitável da tecnologia da informação (TI) dentro de suas organizações.

Este documento é aplicável:

- a governança do uso atual e futuro da TI pela organização;
- a governança de TI como um subconjunto da governança das organizações.

Em termos de públicos-alvo, este documento é aplicável a:

- todas as organizações, incluindo empresas públicas e privadas, entidades governamentais e organizações sem fins lucrativos;
- organizações de todos os tamanhos, do menor ao maior, independentemente da extensão de seu uso de TI.

2 Referências normativas

O documento a seguir é citado no texto de tal forma que seu conteúdo, total ou parcial, constitui requisito para este documento. Para referências datadas, aplicam-se somente as edições citadas. Para referências não datadas, aplicam-se as edições mais recentes do referido documento (incluindo emendas).

ABNT NBR ISO 37000, *Governança de organizações – Orientações*

3 Termo e definição

Para os efeitos deste documento, aplicam-se os termos e definições da ABNT NBR ISO 37000 e os seguintes.

A ISO e a IEC mantêm as bases de dados terminológicos para uso na normalização nos seguintes endereços:

- ISO *Online browsing platform*: disponível em <http://www.iso.org/obp>
- IEC *Electropedia*: disponível em <http://www.electropedia.org/>

3.1

direcionar

comunicar os propósitos e os resultados desejados

Nota 1 de entrada: No contexto da governança de TI, direcionar envolve a definição de objetivos, estratégias e políticas a serem adotadas pelos membros da organização para assegurar que o uso da TI atenda aos objetivos de negócios.

Nota 2 de entrada: Os objetivos, as estratégias e as políticas podem ser definidos pelos gerentes se tiverem autoridade delegada pelo órgão de governança.

3.2

avaliar

considerar e fazer julgamentos informados

Nota 1 de entrada: Dentro do contexto da governança de TI, avaliar envolve fazer julgamentos sobre as circunstâncias e as oportunidades (internas e externas, atuais e futuras) relacionadas ao uso atual e futuro da TI pela organização.

3.3

governança

sistema baseado no ser humano que compreende a direção, a supervisão e a responsabilização

3.4

governança de TI

sistema pelo qual o uso atual e futuro da TI é direcionado

Nota 1 de entrada: Governança de TI é um componente ou um subconjunto da governança organizacional.

Nota 2 de entrada: O termo “governança de TI” é equivalente aos termos “governança corporativa de TI”, “governança empresarial de TI” e “governança organizacional de TI”.

3.5

tecnologia da informação

TI

recursos utilizados para adquirir, processar, armazenar e disseminar informações ou dados

Nota 1 de entrada: Os recursos podem incluir computador ou equipamentos de comunicação, sensores, *software*, computação em nuvem e outros serviços baseados em *software*.

3.6

investimento

alocação de recursos para alcançar objetivos definidos e outros benefícios

3.7

gestão

atendimento aos objetivos da organização dentro da autoridade e da responsabilização estabelecidos pela governança

Nota 1 de entrada: O termo “gestão” é frequentemente utilizado como um termo coletivo para quem é responsável pelo controle de uma organização ou partes de uma organização.

NOTA BRASILEIRA A Nota 1 de entrada não é aplicável no Brasil.

3.8

monitorar

análise crítica como base para decisões e ajustes apropriados

Nota 1 de entrada: O monitoramento envolve a obtenção rotineira de informações sobre o progresso em relação aos planos, bem como o exame periódico das realizações gerais em relação às estratégias e aos resultados acordados, a fim de fornecer uma base para a tomada de decisões e ajustes nos planos.

Nota 2 de entrada: O monitoramento inclui a análise crítica da conformidade com a legislação, os regulamentos e as políticas organizacionais relevantes.

3.9

uso de TI

planejamento, projeto, desenvolvimento, implantação, operação, gestão e aplicação de TI para cumprir os objetivos de negócios e criar valor para a organização

Nota 1 de entrada: O uso de TI inclui tanto a demanda quanto a oferta de TI.

3.10

capacidade digital

capacidade de TI para habilitar ou dar suporte a um serviço, um produto ou um processo organizacional

4 Boa governança de TI

4.1 Resultados da boa governança de TI

4.1.1 Visão geral

Este documento fornece orientação sobre as implicações de governança de TI e seu uso, dados e recursos digitais para uma organização. Ao longo do conceito, esse termo é simplificado como a expressão “a governança de TI”. Enquanto o órgão de governança mantém a responsabilização final por toda a organização, a prática da governança de TI pode ocorrer em toda a organização.

A governança de TI neste contexto é aplicada amplamente ao uso da tecnologia da informação, incluindo tecnologias emergentes, dados e recursos digitais. A tecnologia da informação inclui pessoas, computadores, sensores, *softwares*, serviços e técnicas de computação em nuvem que são usados para coletar, armazenar, processar, disseminar e transformar dados. Os recursos digitais, muitas vezes inovadores, permitem ou apoiam os serviços, os produtos ou os processos da organização que podem criar valor para as partes interessadas. Os recursos digitais da organização são suportados, ou habilitados, usando tecnologia da informação e dados.

A governança de TI é um subconjunto da governança das organizações, por isso este documento se alinha à ABNT NBR ISO 37000 e aos seus princípios de governança. Este documento fornece orientação sobre como os resultados de governança organizacional são alcançados, resultantes de uma governança de TI eficaz.

A ABNT NBR ISO 37000 descreve a governança das organizações como estabelecendo as bases para o cumprimento do propósito da organização de forma eficaz, responsável e ética, em linha com as expectativas das partes interessadas. Ela estabelece 11 princípios de governança para orientar os órgãos de governança no atendimento a suas funções, de modo que as organizações percebam os três resultados de governança pretendidos, que são definidos como:

- desempenho eficaz,
- administração responsável, e
- comportamento ético.

A TI e os dados a partir dos quais cria e desbloqueia valor têm se tornado cada vez mais eficazes e estrategicamente significativos para a maioria das organizações. Isso torna a governança de TI

cada vez mais importante para a organização – e as partes interessadas têm altas expectativas dos resultados de uma governança eficaz de TI.

4.1.2 Desempenho eficaz

O que constitui o desempenho eficaz de TI pela organização é determinado pelo órgão de governança e sua compreensão do contexto da organização e das expectativas das partes interessadas. Para alcançar um desempenho eficaz, expectativas de desempenho claramente declaradas são estabelecidas como base para o gerenciamento operacional, supervisão da entrega e uso de TI.

O desempenho eficaz da TI pela organização também pode ser medido avaliando os seguintes pontos:

- o alinhamento dos recursos digitais para apoiar e permitir o cumprimento do propósito organizacional;
- o investimento adequado em TI, incluindo o grau de digitalização e inovação requerido pela organização;
- a extração de valor adequado de recursos, incluindo ativos de TI, como computadores e *software*, mas também dos dados e dos serviços digitais utilizados e das pessoas que criam, mantêm e utilizam os recursos digitais;
- a ligação entre os custos dos dados e a forma como a utilização dos dados proporciona uma melhor tomada de decisão na organização e nas suas partes interessadas;
- o grau em que as capacidades digitais estão entregando agilidade e adaptabilidade à organização para que ela possa perceber, aprender e se adaptar para lidar com oportunidades futuras, riscos potenciais e novas obrigações.

4.1.3 Administração responsável

Os recursos sob a administração da organização incluem os recursos digitais da organização, bem como os dados que ela criou e dados de outros (como fornecedores, clientes, funcionários e outras partes interessadas).

Convém que as expectativas de uma administração responsável sejam claramente declaradas e podem incluir:

- considerar assegurar que as decisões automatizadas sejam razoáveis e justificadas (ver ABNT NBR ISO/IEC 38507);
- assegurar que os dados relativos às informações das partes interessadas sejam adequadamente protegidos e utilizados;
- assegurar a segurança e a resiliência das capacidades e dos dados digitais;
- demonstrar uma governança adequada dos riscos, o dever de cuidar e boas tomadas de decisões na utilização das capacidades digitais;
- adaptar às novas exigências das partes interessadas em matéria de transparência, explicabilidade e avaliações de impacto.

4.1.4 Comportamento ético

A organização conta com o engajamento de partes interessadas e normas internacionais de comportamento para definir suas práticas éticas e conduzir condutas adequadas. No contexto da utilização de TI, isto significa que essa utilização é adequadamente governada e as expectativas são claramente declaradas para assegurar que a utilização permanece dentro destes parâmetros (incluindo o comportamento humano), e qualquer impacto dessa utilização não afeta negativamente as partes interessadas relevantes ou o ambiente econômico ou natural.

Ao aderir aos princípios da governança de TI e aplicar o modelo e a estrutura ao uso de TI pela organização, o órgão de governança assegura que o comportamento ético seja apoiado e incentivado.

As expectativas de comportamento ético podem incluir:

- consideração da propriedade de ativos de TI e dos direitos e obrigações de dados;
- consideração do acesso e dos direitos de uso;
- consideração de questões sociais e ambientais;
- manutenção da confidencialidade;
- integridade e transparência no atendimento a obrigações e compromissos;
- conformidade com regulamentos.

4.2 Princípios, modelo e estrutura

Este documento fornece três ferramentas para o órgão de governança e as práticas de governança e gestão associadas usarem para alcançar uma governança eficaz de TI. A Tabela 1 descreve essas ferramentas, como elas são utilizadas e os benefícios de sua utilização.

Tabela 1 – Governança de TI – Visão geral das ferramentas (continua)

Ferramenta	Explicação	Uso	Benefício(s)
Princípios para a governança de TI	Fornece a verdade fundamental e os pressupostos que servem de base para crenças, comportamentos e raciocínio.	A aplicação destes princípios em tarefas, interações e elementos de enquadramento permite uma tomada de decisão mais rápida e alinhada, principalmente na ausência de regras claramente definidas (por exemplo, novos mercados, regras de negócio, tecnologias ou inovações em qualquer uma destas áreas).	Um uso mais ágil, adaptativo, responsável e estratégico da TI para suportar e viabilizar os objetivos da organização.

Tabela 1 (conclusão)

Ferramenta	Explicação	Uso	Benefício(s)
Modelo de governança de TI	Apresenta as principais tarefas e interações em toda a organização que são necessárias para a implementação da governança de TI.	O modelo é usado para delinear claramente as responsabilidades e as decisões de governança a partir daquelas da direção, ao mesmo tempo em que entende como essas duas práticas interagem dentro de uma estrutura geral para a governança de TI.	Clareza da tomada de decisões e responsabilidades por todos os aspectos do uso de TI.
Framework para a governança de TI	Descreve os elementos por meio dos quais a governança de arranjos de TI da organização opera.	A prática de governança colabora em toda a organização para detalhar os seis elementos da estrutura. Os princípios são aplicados em toda a colaboração, e o modelo orienta as responsabilidades e a tomada de decisões ao longo de toda a colaboração.	Ajuda a assegurar que as ações críticas de governança sejam consideradas e aplicadas ao uso de TI pela organização.

5 Princípios para a governança de TI

5.1 Visão geral

O benefício de um documento baseado em princípios é que pode identificar os resultados da aplicação dos princípios sem especificar metodologias, estruturas, processos e técnicas explícitas. Como documento fundamental para a governança de TI, é essencial que o documento possa ser aplicado sem considerar a implementação específica de uma organização. Convém que o sistema de governança adotado pela organização seja orientado a resultados para melhor se adequar à organização, incluindo, mas não se limitando a, suas necessidades de *compliance*.

Os princípios para a governança de TI fornecem a verdade fundamental e as suposições que servem de base para crenças, comportamentos e raciocínio (ver Tabela 1). Eles fornecem uma base útil para a governança de TI e fornecerão um valor particular quando o uso novo ou inovador de TI for considerado. Os princípios podem ser aplicados a situações e elementos individuais de TI, bem como em todo o ecossistema de uma organização.

Como a governança de TI é um domínio da governança da organização, as declarações de “princípio” (ver Tabela 2, 5.2 a 5.12) são as fornecidas na ABNT NBR ISO 37000:2022, Seção 6. A Tabela 2 detalha a categoria e o agrupamento dos princípios e é retirada da ABNT NBR ISO 37000:2022, Tabela 1.

As implicações de governança do uso de TI e seus consequentes resultados são detalhados, destacando os aspectos específicos e únicos dos princípios de uma organização em relação à TI.

Tabela 2 – Visão geral dos princípios de governança organizacional

Categoria	Descrição da categoria	Princípio
Primário	A busca do propósito está no centro de todas as organizações e é de primordial importância para a governança das organizações. Portanto, esse princípio é a principal consideração para a governança e o ponto central de todos os outros princípios deste documento. Todos os outros princípios são para serem lidos no contexto da aplicação deste princípio.	Propósito (5.2)
Fundamental	Os quatro princípios fundamentais de governança são a essência para assegurar que a governança efetiva de uma organização ocorra. O núcleo para a capacidade de governar efetivamente uma organização é: — determinar a abordagem da organização para a geração de valor; — direcionar e engajar a estratégia para gerar esse valor; — supervisionar que a organização executa e se comporta de acordo com as expectativas estabelecidas pelo órgão de governança; — demonstrar responsabilização pelo desempenho, comportamento, decisões e atividades da organização.	Geração de valor (5.3)
		Estratégia (5.4)
		Supervisão (5.5)
		Responsabilização (5.6)
Facilitador	Os seis princípios facilitadores abordam as responsabilidades de governança pertinentes às organizações atuais: atender às expectativas das partes interessadas em evolução e ao ambiente natural, contexto social e econômico em mudança.	Engajamento de partes interessadas (5.7)
		Liderança (5.8)
		Dados e decisões (5.9)
		Governança de riscos (5.10)
		Responsabilidade social (5.11)
		Viabilidade e desempenho ao longo do tempo (5.12)

5.2 Propósito

5.2.1 Princípio

“Convém que o órgão de governança assegure que a razão de existência da organização é claramente definida como um propósito organizacional. Convém que esse propósito organizacional defina as intenções da organização em relação ao ambiente natural, à sociedade e às partes interessadas da organização. Convém também que o órgão de governança assegure que um conjunto associado de valores organizacionais seja claramente definido.” [FONTE: ABNT NBR ISO 37000:2022, 6.1.1]

5.2.2 Implicações de governança para o uso de TI

Ao definir o propósito da organização, convém que o órgão de governança considere como o uso da TI pode permitir ou melhorar o propósito organizacional, bem como os valores da organização. Convém considerar as implicações das tecnologias novas e emergentes, comunicadas de uma forma que faça uma utilização adequada das TI e seja integrada por meio de um compromisso contínuo e demonstrado.

À medida que a tecnologia muda, convém que o propósito da organização seja revisto para abordar o potencial de um propósito mais amplo, mais focado ou mais forte, aproveitando essas mudanças. Além disso, convém que o uso de novos serviços de tecnologia seja revisto para assegurar que esse uso permaneça alinhado ao propósito acordado pela organização.

5.2.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Propósito estendido ou aprimorado:** ao alavancar o uso de TI adequadamente, a organização pode aprimorar suas ofertas de valor.
- **Alinhamento da TI ao propósito:** abordar o uso da TI juntamente com o propósito e os valores organizacionais ajuda a alinhar o uso da TI.
- **Capacitar o pessoal:** esclarecer o alinhamento do uso da TI ao propósito organizacional capacita o pessoal a tomar decisões e agir em alinhamento com o propósito.

5.3 Geração de valor

5.3.1 Princípio

“Convém que o órgão de governança defina os objetivos de geração de valor da organização para que seja cumprido o propósito organizacional de acordo com os valores organizacionais e com o ambiente natural, contexto social e econômico em que atua.” [FONTE: ABNT NBR ISO 37000:2022, 6.2.1]

5.3.2 Implicações de governança para o uso de TI

A TI desempenha um papel importante na geração de valor de uma organização, pois pode fornecer produtos ou serviços novos ou aprimorados de maneira oportuna, econômica e de alta qualidade. Ela também pode ser usada para diferenciar o valor da organização para suas partes interessadas, incluindo clientes e fornecedores. O uso da TI pode ter impactos significativos, tanto positivos quanto negativos, no modelo de geração de valor da organização e, portanto, convém que o papel da TI na definição e na geração de valor organizacional seja determinado e comunicado. O conceito de modelo de geração de valor está definido na ABNT NBR ISO 37000:2022, 6.2.3.

As organizações se deparam com um ambiente de mudanças contínuas, muitas vezes impulsionadas por recursos de TI, dados e digitais. Convém que o órgão de governança considere o impacto da mudança tecnológica em seu modelo de geração de valor e assegure que as implicações sejam bem compreendidas e apropriadas ao propósito, aos valores e à capacidade ou à necessidade da organização de mudar ou transformar.

Ao determinar os impactos da TI, dos dados e das capacidades digitais no modelo de geração de valor, convém que o ambiente competitivo, as tendências tecnológicas emergentes e futuras, as soluções tecnológicas alternativas e as tendências nas expectativas das partes interessadas sejam considerados.

Convém que as organizações também assegurem que as oportunidades e as ameaças ao modelo de geração de valor da organização a partir da inovação ou da transformação digital sejam monitoradas. Convém que as oportunidades de inovação sejam identificadas e avaliadas.

Convém que a governança assegure que os recursos digitais da organização sejam apropriados tanto para o uso atual quanto para o uso futuro desejado, em um ritmo de mudança exigido pela organização. O investimento em TI, dados e recursos digitais é fundamental e impacta significativamente o modelo de geração de valor para uma organização. Convém que o investimento no ambiente atual da organização e em seus planos futuros seja considerado para impacto no valor para a organização.

5.3.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Objetivos definidos de geração de valor:** são definidos objetivos sobre como a organização se propõe a utilizar a TI para apoiar e viabilizar seu modelo de geração de valor e orientar as prioridades organizacionais e o investimento em TI.
- **Objetivos de geração de valor comunicados:** a contribuição e a integração das capacidades digitais da organização como um facilitador crítico para o modelo de geração de valor são entendidas e alinhadas à sua estratégia e comunicadas às suas partes interessadas relevantes.
- **Adaptabilidade:** existem mecanismos para avaliar regularmente o impacto potencial de novas soluções tecnológicas e aproveitá-las para o modelo de geração de valor da organização e soluções competitivas.

5.4 Estratégia

5.4.1 Princípio

“Convém que o órgão de governança conduza e se engaje com a estratégia organizacional, de acordo com o modelo de geração de valor, para cumprir o propósito organizacional.” [FONTE: ABNT NBR ISO 37000:2022, 6.3.1]

5.4.2 Implicações de governança para o uso de TI

Convém que a estratégia organizacional geral considere o impacto da TI nas necessidades e nas expectativas atuais e futuras da organização. Convém que o valor potencial e o papel que a TI emergente pode fornecer à organização em tempo hábil, bem como o ritmo e a abordagem usados para integrar TI nova ou emergente, formem elementos fundamentais da estratégia organizacional.

Convém que a estratégia de TI seja alinhada e incluída na estratégia organizacional. Convém identificar onde as escolhas estratégicas têm impacto na utilização das TI, na procura crescente de serviços digitais e no impacto da segurança cibernética, resiliência, custo total de propriedade, flexibilidade e recursos. Convém que seja dada atenção especial à possibilidade de a organização adaptar a sua estratégia para integrar novas oportunidades tecnológicas e adaptar-se às mudanças na procura interna e externa. Convém que a estratégia de TI para o fornecimento e o uso de TI seja revisada criticamente, considerando o ecossistema dentro do qual a organização opera agora e no futuro.

Convém que os serviços informáticos essenciais, como a gestão de identidades em linha, o armazenamento de dados e as comunicações, sejam examinados para assegurar um equilíbrio razoável entre custos, flexibilidade e autonomia e independência organizacionais.

5.4.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Recurso digital:** a estratégia organizacional fornece orientação atual e eficaz para o uso e a entrega das capacidades de TI, dados e digitais da organização.
- **Preparação digital:** a organização faz uso efetivo de novos recursos digitais conforme apropriado, planejando os recursos apropriados, incluindo pessoal.
- **Inovação digital:** a estratégia identifica o nível adequado de investimento em inovação digital para permitir que a organização acelere seus objetivos estratégicos.
- **Ativo digital:** a TI da organização é e continuamente atualizada e alinhada com a estratégia organizacional. A organização tem estratégias para resolver a degradação e a obsolescência de TI ao longo do tempo.

5.5 Supervisão

5.5.1 Princípio

“Convém que o órgão de governança supervisione o desempenho da organização para assegurar que ela atenda às intenções e às expectativas do órgão de governança em relação ao seu comportamento ético e às suas obrigações de compliance.” [FONTE: ABNT NBR ISO 37000:2022, 6.4.1]

5.5.2 Implicações de governança para o uso de TI

Políticas e práticas fornecem a enumeração de intenções e direção dentro das quais uma organização opera para alcançar seus objetivos. Alguns baseiam-se nos requisitos da legislação e nos regulamentos obrigatórios. Outros são baseados nas melhores práticas e orientarão a organização em termos de redução de riscos ou melhorias na eficiência e na eficácia na entrega e no uso de TI. Vale ressaltar que, com a rápida evolução dos avanços das tecnologias digitais, a legislação pode ser pouco clara, subdesenvolvida ou mesmo contraditória. Nesse caso, convém que o órgão de governança aborde os elementos de conformidade que exige da organização.

Convém que o órgão de governança assegure que as políticas apropriadas estão em vigor estão sendo seguidas e que é informado de quaisquer violações significativas ou padrões de violação. A comunicação aberta e a capacidade de demonstrar ou verificar a conformidade com um conjunto aplicável de requisitos regulamentares ou de estrutura voluntária ajudam a organização a ser considerada confiável. Convém que o órgão de governança defina suas expectativas e os mecanismos por meio dos quais o desempenho global é avaliado e por meio dos quais modificações significativas para melhoria são feitas, com foco na geração de valor organizacional.

A consciência das responsabilidades e expectativas do órgão de governança é fundamental para que todos os membros sejam eficazes em seu papel e em seus deveres.

Convém que o órgão de governança tenha supervisão do progresso da gerência na implementação da estratégia de TI e de quaisquer riscos para a organização que possam surgir. Isso requer que o órgão de governança seja informado sobre o progresso na implementação da estratégia de TI da organização, bem como o impacto das mudanças nos ambientes externo e interno da organização, para identificar áreas em que a estratégia precisa ser ajustada.

Os recursos digitais da organização geralmente são compostos por TI fornecida por terceiros por meio de acordos contratuais, como contratos de serviço ou terceirização de processos de negócios. Convém que essas políticas abranjam as intenções e as expectativas do órgão regulador quanto ao uso ético da TI, bem como suas obrigações de *compliance*. A supervisão da estratégia geral de *sourcing* e desses arranjos e responsabilidades pode ser uma questão-chave de governança para a organização. Ver as séries ISO/IEC 20000 e ISO/IEC 30105, respectivamente, para obter orientações de gerenciamento relacionadas.

Convém que o órgão regulador supervisione o ciclo de vida de ponta a ponta da provisão de tecnologia, desde a adoção de novas tecnologias até a aposentadoria de tecnologia e dados desatualizados. Convém considerar a resiliência das capacidades digitais e o uso efetivo e otimizado do capital técnico e de dados dentro da organização.

5.5.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Compliance:** obrigações relacionadas à TI, tanto internas quanto externas (regulatórias, legislativas, de direito comum, contratuais), foram identificadas com as ações planejadas.
- **Informado:** convém que o órgão de governança seja informado em tempo hábil de quaisquer violações materiais, particularmente em conformidade regulatória ou contratual, e quaisquer riscos para a organização relacionados à TI.
- **Desempenho eficaz:** existem processos para assegurar a transparência e que o fluxo de informações e as medições de desempenho associadas auxiliem a governança e a tomada de decisões.

5.6 Responsabilização

5.6.1 Princípio

“Convém que o órgão de governança demonstre sua responsabilização perante a organização como um todo e responsabilize aqueles a quem delegou.” [FONTE: ABNT NBR ISO 37000:2022, 6.5.1]

5.6.2 Implicações de governança para o uso de TI

Convém que o órgão de governança assegure que as respectivas responsabilidades e responsabilizações pela entrega e utilização de TI sejam claras. Convém que também haja uma estratégia clara para assegurar que aqueles que usam TI, aqueles que são responsáveis pelos produtos e serviços que a TI fornece e aqueles que têm o conhecimento de TI apropriado estejam envolvidos na tomada de decisões relacionadas à TI aplicáveis às suas responsabilidades, com mecanismos de suporte apropriados. Isso maximiza os benefícios e, ao mesmo tempo, minimiza o risco associado à entrega.

Convém que o órgão de governança assegure que, quando necessário, a formulação e a tradução de suas intenções sejam apoiadas por pessoal com a competência apropriada em toda a organização. A responsabilização pela governança de TI permanece com o órgão de governança, independentemente das estratégias de implementação e delegação de responsabilidades.

5.6.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Responsabilidade do órgão de governança:** a responsabilização pela governança de TI permanece com o órgão de governança, independentemente da delegação.
- **Tomada de decisão integrada:** o desenho das estruturas de tomada de decisão e os arranjos de supervisão incluem aqueles na organização responsáveis pela entrega, bem como aqueles que usam os serviços de TI, com autoridade delegada àqueles mais bem posicionados para exercê-la.
- **Garantia:** há garantia de que a estrutura para a governança de TI é eficaz e há o controle de supervisão apropriado do uso de TI.

5.7 Engajamento de partes interessadas

5.7.1 Princípio

“Convém que o órgão de governança assegure que as partes interessadas da organização estejam devidamente engajadas e suas expectativas consideradas.” [FONTE: ABNT NBR ISO 37000:2022, 6.6.1]

5.7.2 Implicações de governança para o uso de TI

Convém que o uso de TI pela organização esteja alinhado aos requisitos das partes interessadas da organização. A satisfação das partes interessadas em relação às capacidades digitais é um fator crítico para alcançar os benefícios do investimento em TI. A retenção de clientes e o engajamento do pessoal são fatores essenciais para o uso bem-sucedido da TI. Convém que a abordagem da organização para o planejamento, a implementação e a operação de TI e os acordos de serviços de suporte abordem as expectativas das partes interessadas para aumentar a satisfação e a confiança.

O engajamento das partes interessadas não envolve apenas a interface de um sistema, mas toda a abordagem da organização por meio da qual as partes interessadas, incluindo clientes, fornecedores, entidades reguladoras e pessoal, interagem com a organização por meio da TI. Cada vez mais, há uma necessidade de uma abordagem estratégica clara para o planejamento, a implementação e a operação de sistemas e os acordos de suporte para atender ou exceder as expectativas das partes interessadas e alcançar uma maior satisfação e confiança das partes interessadas e dos usuários finais. É fundamental que o investimento em TI esteja alinhado com os requisitos das partes interessadas e os objetivos organizacionais.

Convém que o órgão de governança identifique as partes interessadas, incluindo aquelas que utilizam a TI da organização, e considere todo o percurso realizado pelas partes interessadas para monitorar a satisfação geral do uso de TI. Convém que haja uma estratégia eficaz de engajamento das partes interessadas em vigor.

Convém que o órgão de governança também assegure que a cultura organizacional permita o alcance bem-sucedido dos objetivos estratégicos, principalmente ao introduzir mudanças. A cultura influencia a maneira como indivíduos e grupos dentro da organização interagem com a TI. A cultura pode

assim impactar a capacidade da organização de usar a TI para alcançar seus objetivos. A eficácia da participação de um indivíduo em todos os aspectos da TI é influenciada pela cultura da organização.

5.7.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Abordagem centrada nas partes interessadas:** há uma abordagem planejada para o engajamento das partes interessadas, para que aqueles afetados pelas decisões possam influenciar o resultado. As políticas, os modelos e as estruturas da organização apoiam uma abordagem centrada nas partes interessadas.
- **Cultura de apoio:** a liderança da organização, as políticas e as práticas influenciam positivamente o comportamento humano e organizacional na entrega e no uso de TI.

5.8 Liderança

5.8.1 Princípio

“Convém que o órgão de governança lidere a organização de forma ética e eficaz, e assegure tal liderança em toda a organização.” [FONTE: ABNT NBR ISO 37000:2022, 6.7.1]

5.8.2 Implicações de governança para o uso de TI

Convém que o órgão de governança assegure uma liderança ética em todo o uso de TI da organização, de forma consistente com seus valores organizacionais.

Convém que a mudança organizacional proporcionada pela TI seja apoiada por uma visão clara dos resultados desejados, juntamente com a capacidade de entregar a mudança necessária para alcançar os resultados planejados. Convém que o nível em que a organização adota a transformação de negócios, por meio e apoiada pela transformação digital, seja definido e promovido em toda a liderança da organização. Convém que o órgão de governança estabeleça o propósito da organização, o modelo de geração de valor e os valores organizacionais, para alcançar os objetivos de TI e assegurar a satisfação das partes interessadas.

Convém que o cenário digital, para abordar o propósito da organização, seja claramente identificado e comunicado em toda a organização.

A entrega de valor a partir da mudança proporcionada pela TI geralmente é complexa. Convém que o órgão de governança tenha assegurado que a organização possui o conhecimento e as habilidades organizacionais e de TI necessárias para implementar a mudança de forma oportuna. Convém que o órgão de governança considere suas próprias competências em relação à TI e o impacto do uso da TI em todas as partes interessadas. Convém que o órgão de governança melhore continuamente e alinhe seu conhecimento em TI de acordo com os requisitos sociais e organizacionais. Convém que assegure que a supervisão seja realizada adequadamente e que haja uma avaliação contínua para assegurar responsabilização e supervisão da tomada de decisões estratégicas e do uso de TI.

5.8.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Capacidade de transformação:** a organização possui uma capacidade de mudança organizacional e de TI apropriada ao nível de mudança organizacional, à complexidade e à velocidade de mudança.

- **Adaptabilidade tecnológica:** uma abordagem gerenciada e flexível para adquirir ou alterar serviços de TI, apoiando a mudança organizacional promovida pela TI.
- **Cultura de aprendizado:** a organização possui uma cultura de aprendizado com uma estratégia integrada de competências e habilidades em TI para necessidades futuras e alcance dos objetivos da organização.

5.9 Dados e decisões

5.9.1 Princípio

“Convém que o órgão de governança reconheça os dados como um recurso valioso para a tomada de decisões pelo órgão de governança, pela organização e por outros.” [FONTE: ABNT NBR ISO 37000:2022, 6.8.1]

5.9.2 Implicações de governança para o uso de TI

Reunir dados e processá-los em informações para serem utilizadas na tomada de decisões é um dos principais objetivos da TI e é cada vez mais um facilitador essencial de valor organizacional. Por meio do acesso a dados de várias fontes, e usando ferramentas como Inteligência Artificial (IA), as organizações podem tomar decisões estratégicas e operacionais de uma forma melhor e mais rápida para impulsionar valor por meio de aperfeiçoamento de serviços, respostas mais imediatas ou custos reduzidos.

Como os dados são utilizados para tomar decisões, por máquinas e pessoas, eles são valiosos não apenas para a própria organização, mas também como um recurso que pode ser comprado, vendido ou de outra forma distribuído. Por exemplo, os dados são recursos usados em produtos e em seu *design*, em *insights* de mercado e clientes e em informações de uso de cadeia de suprimentos e produtos.

Convém que o papel dos dados na geração de valor seja claro e alinhado à estratégia da organização. Convém assegurar que a organização possa adquirir, usar e proteger dados de forma eficaz. Convém que o órgão de governança assegure que haja uma clara estratégia de dados que aborde o seguinte:

- a) objetivos estratégicos para o uso de dados;
- b) governança de dados e responsabilidades de proteção de dados;
- c) estratégias para ativos de dados, incluindo classificação, compartilhamento e uso;
- d) garantia das obrigações e restrições impostas ao uso de dados por outros;
- e) garantia de que os direitos de dados relativos ao uso sejam respeitados quando esses dados forem disseminados para outros;
- f) que os dados sejam utilizados de acordo com o propósito e os valores organizacionais.

5.9.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Uso estratégico de dados:** o papel do uso de dados é claramente definido na estratégia da organização. Os dados são usados em todos os aspectos da organização, incluindo seus

produtos, serviços e geração de valor. Portanto, é importante entender como ele adiciona valor, risco e obrigações aos objetivos da organização.

- **Uso responsável de dados:** a organização pode demonstrar seu uso responsável de dados. Isso inclui assegurar que os dados sejam apropriados para seu uso (incluindo obrigações como privacidade e direitos autorais), que tenham a qualidade necessária (incluindo a ausência de viés indesejado) e que sejam protegidos contra roubo, fraude e uso malicioso.
- **Qualidade de dados necessária:** os requisitos de qualidade são considerados e mecanismos estão em vigor para assegurar que os dados atendam a esses requisitos.

5.10 Governança de riscos

5.10.1 Princípio

“Convém que o órgão de governança assegure que considera o efeito da incerteza no propósito organizacional e os resultados estratégicos associados.” [FONTE: ABNT NBR ISO 37000:2022, 6.9.1]

5.10.2 Implicações de governança para o uso de TI

A governança de riscos é fundamental para a governança e a gestão eficaz da entrega e do uso de TI. Convém que a compreensão dos riscos, das ameaças e das oportunidades relacionados à TI para que a organização oriente o foco da governança de TI e proveja uma base para o *framework* de governança para TI. Riscos de segurança cibernética, a incerteza associada a tecnologias emergentes e os potenciais impactos adversos decorrentes do uso acidental ou intencionalmente antiético de TI são áreas críticas e de foco para a governança de riscos de TI.

Convém que o órgão de governança assegure o conhecimento e a comunicação dos riscos estratégicos ou críticos associados à TI e que um processo sólido para gestão de riscos relacionados à TI esteja em vigor. Ter uma abordagem baseada em riscos proporciona flexibilidade e agilidade para adotar e adaptar-se a condições em mudança. Além disso, fornece um mecanismo para a priorização da alocação de recursos.

5.10.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Supervisão apropriada de riscos:** o risco crítico ou estratégico associado ao uso de TI é reconhecido e tratado prontamente.
- **Apetite de risco aceitável:** o nível de risco que a organização está disposta a aceitar em relação ao uso de TI na busca de seus objetivos é definido e gerenciado.
- **Resiliência digital:** a organização é capaz de responder e se recuperar de falhas internas de TI ou eventos externos adversos em conformidade com as expectativas das partes interessadas.

5.11 Responsabilidade social

5.11.1 Princípio

“Convém que o órgão de governança assegure que as decisões sejam transparentes e alinhadas às expectativas mais amplas da sociedade.” [FONTE: ABNT NBR ISO 37000:2022, 6.10.1]

5.11.2 Implicações de governança para o uso de TI

Convém que o órgão de governança assegure que suas responsabilidades sociais sejam abordadas em todas as decisões de TI, proporcionando transparência e abordando os impactos para todas as partes interessadas. Com o crescimento da tomada de decisões cada vez mais automatizada, convém ao órgão de governança assegurar que o impacto dessas decisões automatizadas seja o pretendido e que quaisquer consequências não intencionais sejam abordadas rapidamente, mantendo a supervisão humana apropriada.

Convém que o órgão de governança assegure que a responsabilidade da organização e o possível dever legal de cuidado para com suas partes interessadas, incluindo clientes, sejam mantidos.

Convém que a organização seja sensível às expectativas da comunidade sobre o uso de TI, incluindo a necessidade de transparência na tomada de decisões, o impacto da crescente automação e o acesso equitativo aos serviços *on-line* essenciais.

Convém que o impacto ambiental do uso de TI também seja considerado, tanto em nível organizacional quanto entre organizações.

5.11.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes.

- **Responsabilidade social apropriada:** alinhamento com os princípios gerais de tomada de decisões e políticas de TI da organização. A organização assume a responsabilidade pelo uso e as consequências da TI utilizada pela organização.
- **Impacto avaliado e abordado:** reconhecimento claro e compreensão do impacto potencial do uso de TI nas partes interessadas é considerado e planejado antes da implementação.
- **Verificação e equilíbrio éticos:** verificações e equilíbrios éticos são considerados em decisões para assegurar o uso aceitável de TI, dados e algoritmos.

5.12 Viabilidade e desempenho ao longo do tempo

5.12.1 Princípio

“Convém que o órgão de governança assegure que a organização permaneça viável e com desempenho ao longo do tempo, sem comprometer a capacidade das gerações presentes e futuras de atender às suas necessidades.” [FONTE: ABNT NBR ISO 37000:2022, 6.11.1]

5.12.2 Implicações de governança para o uso de TI

Capacidades digitais eficazes agora e no futuro são vitais para a viabilidade de uma organização. Convém que uma direção clara e um caminho para o futuro sejam identificados enquanto mantêm um ambiente atual confiável e sustentável. Convém que a direção inclua resiliência para o futuro da organização do ponto de vista tecnológico. Convém que o órgão de governança compreenda e responda, por meio de uma boa governança de TI, às necessidades do ecossistema no qual a organização opera para permanecer viável e ter desempenho a longo prazo.

Em um ambiente de mudanças rápidas, as organizações precisam ter uma compreensão clara das opções tecnológicas. Convém que o órgão de governança entenda a dependência de funções críticas da TI e assegure que a provisão dos serviços de TI é bem gerenciada e resiliente. Convém que eles

sejam informados sobre quaisquer questões potenciais relacionadas à TI que possam impactar o desempenho da organização.

Convém que a TI seja adequada para a finalidade a qual foi projetada, apoiando o propósito e os objetivos organizacionais, fornecendo serviços, níveis de serviço e qualidade de serviço necessários para atender aos requisitos organizacionais atuais e futuros.

Convém que o órgão de governança minimize quaisquer impactos negativos do uso de TI da organização nos sistemas naturais, sociais e econômicos nos quais a organização opera.

5.12.3 Resultados

Os resultados esperados do uso de TI para a aplicação do princípio são os seguintes:

- **O ecossistema de TI permanece válido para as necessidades da organização:** a provisão de TI é gerenciada para assegurar que os requisitos de negócios sejam identificados, acordados e fornecidos de acordo com as prioridades organizacionais.
- **Gerenciamento de infraestrutura:** os componentes operacionais essenciais, como políticas, processos, equipamentos, dados, recursos humanos e contatos externos, são gerenciados para eficácia geral.
- **Proteção:** as políticas e as práticas da organização asseguram que as operações e as informações sejam protegidas em um ambiente cada vez mais complexo e vulnerável.

6 Modelo para a governança de TI

6.1 Introdução

A governança envolve estabelecer e ser responsabilizável pelo propósito e pelos parâmetros da organização. Embora o órgão de governança mantenha a responsabilização final por toda a organização (e este documento se concentra na responsabilização pelo uso atual e futuro de TI pela organização), a prática de governança ocorre em toda a organização.

A gestão se refere ao atendimento aos objetivos associados, fazendo escolhas dentro dos parâmetros estabelecidos pelo órgão de governança.

A distinção entre os papéis variará entre organizações, mas é importante diferenciar entre as diversas responsabilidades, decisões e ações requeridas por cada papel. Mesmo que uma pessoa seja encarregada de ambos os papéis de governança e gestão, essa separação e clareza de papéis auxiliam na obtenção de resultados eficazes de governança.

Toda a organização opera dentro de um *framework* de governança, e este documento se concentra no *framework* para a governança de TI - ou seja, as estratégias, as políticas, as estruturas de tomada de decisão e as responsabilizações por meio das quais o uso de TI da organização opera hoje e planeja para o futuro.

A responsabilidade por aspectos específicos de TI pode ser delegada à gestão dentro da organização. No entanto, a responsabilização pelo uso eficaz, eficiente e aceitável de TI por uma organização permanece com o órgão de governança e não pode ser delegada.

A Figura 1 apresenta o modelo para a governança de TI. Este modelo consiste em:

- 1) **prática de governança de TI**, compreendendo as quatro principais tarefas de “envolver as partes interessadas”, “avaliar”, “direcionar” e “monitorar” (como representado pelo triângulo);
- 2) **gestão da prática de TI** (como representado pelo retângulo); e
- 3) **framework para a governança de TI** (como representado pelo círculo), dentro do qual toda a organização opera.

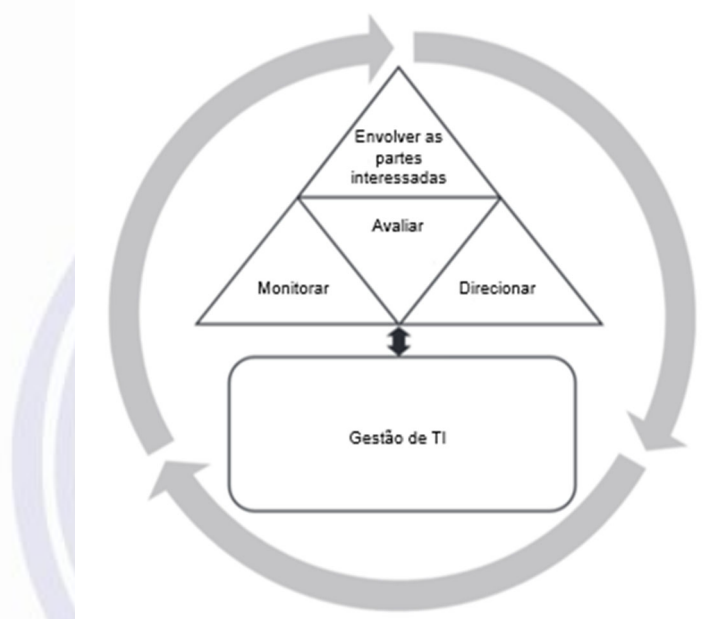


Figura 1 – Modelo para governança de TI

6.2 Governança da prática de TI

6.2.1 Envolver as partes interessadas

Convém que as partes interessadas pertinentes ao uso de TI pela organização sejam identificadas, consultadas e envolvidas de maneira apropriada. Essas partes interessadas provavelmente são internas à organização (por exemplo, usuários de TI, funcionários e desenvolvedores), bem como externas (por exemplo, clientes, fornecedores, governos).

Entender as expectativas das partes interessadas pertinentes ajuda a organização a estabelecer políticas e comportamentos adequados para que os resultados desejados de governança sejam compreendidos e suas obrigações de responsabilização possam ser definidas. Em especial, convém que a organização assegure que haja uma declaração clara de compromissos referentes ao uso de TI e dados e que quaisquer violações desses compromissos sejam comunicadas prontamente para permitir que a organização e suas partes interessadas lidem com as consequências.

O envolvimento com as partes interessadas pertinentes também permite que as capacidades do uso de TI sejam discutidas, e a compreensão desse potencial pode alterar as expectativas das partes interessadas.

6.2.2 Avaliar

Convém que o órgão de governança examine e julgue o uso atual e futuro de TI, incluindo planos, propostas e acordos de fornecimento (sejam internos, externos ou ambos).

Ao avaliar o uso de TI, convém que o órgão de governança considere as pressões externas ou internas que atuam sobre a organização, como mudanças tecnológicas, tendências econômicas e sociais, obrigações regulatórias, expectativas legítimas das partes interessadas e influências políticas. Convém que o órgão de governança realize avaliações continuamente à medida que as circunstâncias mudam. Convém que o órgão de governança também considere tanto as necessidades de negócios atuais quanto futuras, ou seja, os objetivos organizacionais atuais e futuros que pretendem alcançar, como manter vantagem competitiva, bem como os objetivos específicos dos planos e das propostas que estão avaliando.

6.2.3 Dirigir

Convém que o órgão de governança atribua responsabilidade pela preparação e implementação de estratégias e políticas e dirija isso. Convém que as estratégias definam a direção para investimentos em TI e o que convém que a TI deve alcançar. Convém que as políticas estabeleçam comportamentos aceitáveis no uso de TI.

Convém que o órgão de governança incentive uma cultura de governança eficaz de TI em sua organização, exigindo que a gestão forneça informações oportunas, atenda às diretrizes e aos onze princípios de governança eficaz.

Se necessário, convém que o órgão de governança dirija a apresentação de propostas para aprovação para abordar as necessidades identificadas.

6.2.4 Monitorar

Convém que os órgãos de governança monitorem o desempenho da TI, por meio de sistemas de medição adequados. Convém a eles assegurar que o desempenho esteja de acordo com as estratégias, principalmente em relação aos objetivos de negócios.

Convém também que os órgãos de governança assegurem que a TI esteja em conformidade com obrigações externas (regulatórias, legislativas, contratuais) e práticas internas de trabalho.

6.3 Gestão da prática de TI

Dada a direção e os parâmetros nos quais a organização irá operar, a prática de gestão utiliza um sistema de gestão de elementos inter-relacionados ou interativos para estabelecer políticas de gestão, objetivos e processos para alcançar esses objetivos. Além disso, há um compromisso de melhoria contínua do sistema de gestão.

6.4 Framework para a governança de TI

Não convém que a governança e a gestão operem separadamente ou independentemente. A colaboração entre essas práticas é essencial para resultados eficazes de governança, incluindo o cumprimento do propósito da organização, a realização de seus objetivos e a entrega do desempenho e do comportamento esperados pelas partes interessadas.

O *framework* para a governança de TI (ver Seção 7) descreve essa colaboração, bem como outros mecanismos para estabelecer políticas, assegurar uma boa tomada de decisão em toda a organização e assegurar que o órgão de governança possa permanecer responsável pelo uso da TI pela organização.

7 Framework para a governança de TI

7.1 Geral

A Figura 2 apresenta o *framework* para a governança de TI, que inclui seis elementos pelos quais as práticas de governança de TI da organização operam. Isso envolve estabelecer e manter políticas, estruturas de tomada de decisão, comportamentos e mecanismos de responsabilização necessários para assegurar que o modelo operacional esteja entregando valor, os riscos sejam gerenciados e outras expectativas das partes interessadas sejam atendidas. Os seis elementos são detalhados em 7.2.2 a 7.2.7.

Os seis elementos do *framework* para a governança de TI envolvem o órgão de governança, bem como aqueles que praticam a governança em toda a organização. As interações em toda a organização são complexas, e esses elementos são iterativos, portanto, não é para serem considerados como um único processo.

Como indicado pelo modelo de governança de TI (ver Seção 6), os detalhes reais do *framework* serão estabelecidos pela organização em relação ao seu contexto, estrutura e propósito. Por exemplo, enquanto o órgão de governança permanece responsabilizável, sua delegação para outros na organização variará. Em qualquer caso, tanto a governança quanto outras funções utilizam o *framework* para interagir e assegurar a governança adequada de TI em todos os níveis da organização.

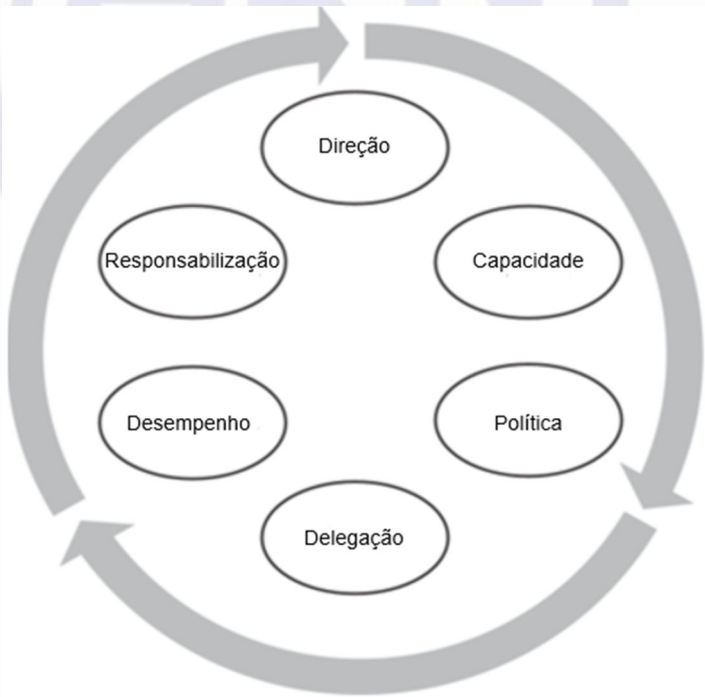


Figura 2 – Framework para a governança de TI

Ao adotar esse *framework*, a estrutura de governança busca:

- permanecer responsabilizável pelo uso de TI, dados e capacidades digitais;
- assegurar que as decisões e as atividades da organização estejam em conformidade com suas políticas e obrigações;
- assegurar a gestão responsável dos recursos;

- aprimorar as capacidades de percepção e adaptação da organização para que ela possa ser resiliente aos riscos e capaz de aproveitar novas oportunidades;
- entregar metas estratégicas e desempenho eficaz para cumprir o propósito da organização.

7.2 Elementos do *framework*

7.2.1 Geral

Como indicado pela Figura 2, convém que o *framework* forneça a base para um ciclo de melhoria contínua nas estruturas de governança. Esse ciclo, baseado em uma avaliação regular da direção e da capacidade necessárias, incluindo os resultados das atividades de garantia, permite que a organização adapte sua estrutura de governança ao seu ambiente interno e externo.

7.2.2 Direção

O órgão de governança analisa criticamente e estabelece a direção para assegurar intenção, alinhamento e clareza no uso da TI pela organização.

Essa direção clara (ver 6.2.3) é baseada em estratégias e monitoramento regular para permitir que a organização reaja às mudanças nos ambientes interno e externo.

Convém que as estratégias que afetam a direção do uso da TI considerem o propósito, os objetivos e o modelo de geração de valor da organização, bem como os seguintes pontos:

- Tecnologias de informação emergentes que possam afetar a direção definida e as capacidades digitais da organização. Por exemplo, a migração para a computação em nuvem pode alterar a combinação de despesas de capital e operacionais, além de fornecer capacidades como escalabilidade sob demanda e redundância global de serviços.
- Uso da TI da organização por partes interessadas externas, incluindo clientes e fornecedores.
- Modos de geração de valor (ver 5.3) habilitados pela TI incorporada, como a incorporação de funcionalidades de TI em produtos para criar serviços contínuos, por exemplo, navegação, manutenção sob demanda, comunicação ou serviços comunitários.

7.2.3 Capacidade

As práticas de governança e gestão trabalham juntas para identificar as capacidades digitais existentes e aquelas necessárias para apoiar e habilitar o propósito da organização.

As capacidades digitais permitem ou suportam os serviços, os produtos ou os processos da organização que podem agregar valor e são suportados ou habilitados por meio da TI e dados. Convém que elas sejam orquestradas para entregar as capacidades globais da organização. Por exemplo, a capacidade digital de “pedidos de clientes” pode consistir em muitos serviços digitais de diferentes provedores de TI dentro do ecossistema da organização (incluindo os serviços internos da organização), orquestrados juntos para permitir que os clientes façam pedidos por meio de diversos canais (como *web*, voz, loja física ou por meio de uma API).

Há três aspectos nas capacidades digitais de uma organização:

- a) **Identificação:** o que a capacidade digital realmente é e o que ela faz (a capacidade digital é usada pela organização, mas não precisa ser de propriedade ou operada pela organização).

- b) **Governança:** o motivo que essa capacidade digital é usada e as diretrizes pelas quais ela opera.
- c) **Gestão:** como essa capacidade digital opera, interage com outras capacidades e relata seu desempenho e conformidade.

A identificação, a governança e o gerenciamento da capacidade digital existente e necessária é um processo contínuo e requer a colaboração de muitas funções dentro da organização.

O “porquê” e o “como” das capacidades digitais são descritos pela política (ver 7.2.4).

NOTA “Capacidade” aqui se refere a uma habilidade que a organização usa para alcançar seus objetivos. Isso é diferente de “competência”, que são as habilidades humanas ou proficiência necessária para concluir uma tarefa com sucesso.

7.2.4 Política

A política para a governança de TI é estabelecida para refletir as decisões do órgão de governança e orientar o uso, as expectativas e o impacto da TI na organização.

A política de governança descreve a estratégia, os parâmetros (incluindo apetite por risco, comportamento aceitável, foco de mercado etc.), a estrutura ampla e outras decisões e intenções para a organização. Ao especificar a política (e deliberadamente não prescrever alguns aspectos da política para permitir flexibilidade), convém a organização que saiba o que fazer, porque fazer e as diretrizes de acordo com as quais é para ser feito.

A organização pode demonstrar sua eficaz governança de TI demonstrando em suas políticas que:

- a) as necessidades, as expectativas e os riscos do uso de TI foram identificados;
- b) o contexto e a capacidade digital são compreendidos (incluindo impactos potenciais internos e externos);
- c) as opções foram apresentadas e exploradas;
- d) a decisão e sua explicação estão documentadas (possivelmente pelos próprios sistemas);
- e) a política está estabelecida e mantida, e possui controles de gerenciamento de suporte;
- f) a supervisão (da governança e da direção) forneceu *feedback* que foi abordado, incluindo que:
 - 1) a política é interpretada corretamente e de maneira razoável,
 - 2) os dados sustentam a interpretação,
 - 3) a prática está alinhada com a política e com a estratégia.

Pode haver muitos níveis diferentes de “política”, desde uma declaração de política ampla que descreve o propósito da organização até um nível muito mais detalhado que descreve uma capacidade digital. A TI está cada vez mais orientada por políticas, o que significa que a política direciona, configura, gerencia e relata diretamente as capacidades digitais. Por exemplo, uma política de nível inferior pode descrever as capacidades de “escala” de um sistema de pedidos, de modo que um grande aumento no número de clientes possa resultar no uso automático de mais armazenamento de dados e mais capacidade de processamento. Políticas semelhantes podem causar automaticamente mudanças na configuração das máquinas no chão de fábrica, aumentando assim significativamente a agilidade de uma organização de manufatura.

Portanto, a “política”, conforme descrita nesta subseção, funciona em todos os níveis da organização.

7.2.5 Delegação

A delegação de autoridade e a responsabilidade associada ao uso de TI são suportadas por práticas de governança e estruturas organizacionais.

A delegação é uma parte importante dos arranjos de supervisão da governança de TI. Além disso, a delegação apropriada de autoridade e a alocação de responsabilidade para a entrega de capacidade digital asseguram que os objetivos do processo estejam alinhados com os requisitos organizacionais. As práticas de delegação e supervisão em todo o ecossistema da organização precisam de suporte cuidadoso das práticas de governança de ponta a ponta.

As funcionalidades emergentes de TI podem impactar os arranjos existentes de delegação e supervisão, pois essas ferramentas podem dar mais poder e impacto aos usuários. A organização precisa assegurar que essa funcionalidade de TI não exceda a autoridade ou as responsabilidades de seus usuários (para uma discussão sobre supervisão de governança de IA, ver ABNT NBR ISO/IEC 38507:2023, 6.2).

O uso das capacidades digitais da organização em todo o ecossistema da organização, como fornecedores, clientes e reguladores, pode ajudar na automação e adicionar rapidamente valor (por exemplo, clientes fazendo pedidos, fornecedores verificando estoque, reguladores monitorando conformidade). No entanto, isso também pode significar que os arranjos de delegação e supervisão precisam ser estendidos além dos limites usuais da organização.

7.2.6 Desempenho

Expectativas de desempenho claramente definidas são estabelecidas pelo órgão de governança como base para sua própria medição, bem como para a gestão operacional e a medição do uso de TI.

O monitoramento do desempenho também pode sugerir áreas de melhoria.

Convém que as medições de desempenho incluam o grau em que a TI está melhorando a organização como um todo, por exemplo, medindo sua segurança, proteção, resiliência e capacidade de adaptação a condições em constante mudança.

Os intervalos de medição existentes para a TI podem ser insuficientes para assegurar um controle adequado de desempenho. Por exemplo:

- técnicas de desenvolvimento e operação ágeis podem causar mudanças rápidas nas capacidades de TI.
- automação, ameaças de segurança cibernética e IA podem alterar os resultados muito rapidamente.

Nesses casos, convém que a organização considere os alertas proativos ou preditivos, além do monitoramento. Convém que algumas capacidades de TI sejam monitoradas em relação aos parâmetros de governança e gestão, com alertas para um ser humano quando esses limites podem ser potencialmente excedidos.

Para obter mais informações sobre a avaliação da governança de TI, ver ISO/IEC 38503.

7.2.7 Responsabilização

Para demonstrar responsabilização em sua governança de TI:

- a estrutura de governança assegura que as políticas da organização relacionadas ao uso de TI reflitam as expectativas de suas partes interessadas.
- essas políticas são compreendidas e cumpridas, e esta conformidade é relatada ou divulgada adequadamente.

O órgão de governança utiliza vários mecanismos para demonstrar sua responsabilização, incluindo processos de TI apropriados, estruturas, relatórios, sistemas de monitoramento e alerta. Garantias adicionais podem ser fornecidas por meio de auditorias. A gestão de desempenho e conformidade pode ser significativamente aprimorada por meio da implementação de Normas de Sistema de Gestão apropriados e relevantes. Para obter mais informações sobre gestão de *compliance*, ver ABNT NBR ISO 37301.

Outros fatores a serem considerados nos requisitos de responsabilização do uso de TI incluem o seguinte:

- sistemas de IA podem se adaptar a circunstâncias em constante mudança (ver ABNT NBR ISO/IEC 38507), e isso pode alterar a adequação dos mecanismos de garantia atuais. Múltiplos mecanismos de garantia podem ser necessários para lidar com diferentes resultados de entradas semelhantes.
- a TI pode fornecer algum grau de garantia automatizada, mesmo se houver uma mudança nas políticas a serem cumpridas. No entanto, saber o que automatizar e o que requer auditoria manual será um desafio contínuo para os auditores e o órgão de governança.

Bibliografia

- [1] ISO/IEC TS 38501, *Information technology – Governance of IT – Implementation guide*
- [2] ISO/IEC TR 38502, *Information technology – Governance of IT – Framework and model*
- [3] ISO/IEC 38503, *Information technology – Governance of IT – Assessment of the governance of IT*
- [4] ISO/IEC TR 38504, *Governance of information technology – Guidance for principles-based standards in governance of information technology*
- [5] ABNT NBR ISO/IEC 38505-1, *Tecnologia da Informação – Governança da TI - Parte 1: Aplicação da ABNT NBR ISO/IEC 38500 à governança de dados*
- [6] ISO/IEC TS 38505-3, *Information technology – Governance of data – Part 3: Guidelines for data classification*
- [7] ISO/IEC 38506, *Information technology – Governance of IT – Application of ISO/IEC 38500 to the governance of IT enabled investments*
- [8] ABNT NBR ISO/IEC 38507:2023, *Tecnologia da informação – Governança de TI – Implicações de governança do uso de inteligência artificial pelas organizações*
- [9] ISO/IEC 20000 (all parts), *Information technology – Service management*
- [10] ISO/IEC 30105 (all parts), *Information technology – IT Enabled Services-Business Process Outsourcing (ITES-BPO) lifecycle processes*
- [11] ABNT NBR ISO 31000, *Gestão de riscos – Diretrizes*
- [12] ABNT NBR ISO 31010, *Gestão de riscos – Técnicas para o processo de avaliação de riscos*
- [13] United Nations, United Nations sustainability development goals [online]. Disponível em <https://www.un.org/sustainabledevelopment/sustainable-development-goals/>
- [14] ISO/IEC JTC 1/SC 40, Information on the governance of IT [online]. Disponível em <https://committee.iso.org/sites/jtc1sc40/home/projects/wg-1/published-wg1.html>